Rapport d'appréciation des risques — Carthago FinTech

Document	Rapport d'appréciation des risques de sécurité de l'information
Référence	ISO/IEC 27001:2022, clauses 6.1.2 et 8.2
Version	1.1 — octobre 2026
Statut	Cotation proposée, à valider avec les propriétaires de risques
Organisation	Carthago FinTech (organisation fictive, étude de cas pédagogique)

1. Objet et périmètre

Ce rapport présente l'appréciation des risques du futur SMSI de Carthago FinTech sur le périmètre proposé dans l'étude de cas : la plateforme CarthagoPay, son infrastructure Azure, les activités DevSecOps, IAM et SOC, et les processus support associés. Il part des 45 écarts recensés dans `registres/Liste_des_ecarts.xlsx` et les regroupe en 11 scénarios de risque (R-01 à R-11). Un douzième risque (R-12, accès physique au siège) a été ajouté lors de l'établissement de la déclaration d'applicabilité, car les contrôles physiques applicables au siège n'étaient couverts par aucun risque.

2. Méthode

La méthode est détaillée dans 05-methodologie-de-risque.md. En bref : chaque scénario est coté de 1 à 4 en **vraisemblance** et en **impact** ; le **niveau** est leur produit.

Niveau	Classe	Décision
12 à 16	Critique	À traiter en priorité
8 à 11	Élevé	À traiter
4 à 7	Modéré	À traiter ou à accepter formellement
1 à 3	Faible	Acceptable (seuil d'acceptation proposé : niveau ≤ 3)

Les échelles et seuils sont des propositions à faire approuver par la direction (clause 6.1.2 a). Chaque cote est justifiée par un fait de l'étude de cas (§ = section de l'énoncé).

3. Résultats

Avant traitement : 2 risques **critiques**, 9 **élevés**, 1 **modéré**. Après traitement, aucun risque n'est critique ni élevé.

ID	Risque	Propriétaire	V	I	Niveau	Classe	Option	V rés.	I rés.	Niveau rés.	Classe rés.
R-01	Compromission d'un compte privilégié	CISO	3	4	12	Critique	Réduire	2	3	6	Modéré
R-02	Détection et réponse tardives à une intrusion	CISO	3	3	9	Élevé	Réduire	2	3	6	Modéré
R-03	Comptes actifs non justifiés (départs, externes, mobilités)	CISO	3	3	9	Élevé	Réduire	2	3	6	Modéré
R-04	Exposition de secrets et d'identifiants techniques	CTO	2	4	8	Élevé	Réduire	1	3	3	Faible
R-05	Mauvaise configuration cloud entraînant une exposition	CIO	3	3	9	Élevé	Réduire	2	3	6	Modéré
R-06	Mise en production de code vulnérable	CTO	3	3	9	Élevé	Réduire	2	3	6	Modéré

R-07	Indisponibilité prolongée de la plateforme de paiement	CIO	2	4	8	Élevé	Réduire	2	3	6	Modéré
R-08	Défaillance d'un fournisseur critique ou de sa sécurité	CISO	2	4	8	Élevé	Réduire	2	3	6	Modéré
R-09	Non-conformité réglementaire ou contractuelle	Risques & Conformité (DPO)	3	3	9	Élevé	Réduire	1	3	3	Faible
R-10	Divulgation de données sensibles hors des circuits prévus	CISO	3	3	9	Élevé	Réduire	2	3	6	Modéré
R-11	Gouvernance du SMSI insuffisante	CEO	4	3	12	Critique	Réduire	2	2	4	Modéré
R-12	Accès physique non autorisé ou perte d'équipement au siège	CIO	2	2	4	Modéré	Réduire	1	2	2	Faible

Carte des risques avant traitement

Vraisemblance \ Impact	1 Mineur	2 Modéré	3 Majeur	4 Critique
4 Quasi certain	·	·	R-11	·
3 Probable	·	·	R-02, R-03, R-05, R-06, R-09, R-10	R-01
2 Possible	·	R-12	·	R-04, R-07, R-08
1 Rare	·	·	·	·

Carte des risques résiduels (cibles après traitement)

Vraisemblance \ Impact	1 Mineur	2 Modéré	3 Majeur	4 Critique
4 Quasi certain	·	·	·	·
3 Probable	·	·	·	·
2 Possible	·	R-11	R-01, R-02, R-03, R-05, R-06, R-07, R-08, R-10	·
1 Rare	·	R-12	R-04, R-09	·

4. Analyse par risque

R-01 — Compromission d'un compte privilégié

- **Scénario** : Un attaquant obtient les identifiants d'un administrateur (phishing, fatigue MFA) ; des droits hérités et l'absence de PAM lui permettent d'agir sur Azure ; fuite, altération ou arrêt de services.
- **Propriétaire** : CISO
- **Écarts liés** : IAM-01 ; IAM-02 ; IAM-03 ; IAM-04 ; IAM-06 ; HUM-01
- **Cotation** : vraisemblance 3, impact 4, niveau 12 (Critique)
- **Justification** : Vraisemblance 3 : l'événement s'est déjà produit le 3 sept. 2026 (§13) et ses causes (droits hérités, PAM en pilote) subsistent. Impact 4 : un rôle privilégié Azure peut toucher les données de transaction et la disponibilité de la plateforme ; l'incident a été classé majeur.
- **Traitement** : Réduire — actions T-01 ; T-02 ; T-03 ; T-04 ; T-05 ; T-33 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.16 ; A.5.18 ; A.8.2 ; A.8.5 ; A.6.3
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : l'accès à la demande et le MFA résistant au phishing rendent l'événement moins probable (2) et limitent l'étendue des droits (impact 3).

R-02 — Détection et réponse tardives à une intrusion

- **Scénario** : Des sources de logs non intégrées et un contrat MSSP non à jour retardent l'alerte et l'escalade ; l'attaquant reste actif plus longtemps.

- **Propriétaire** : CISO
- **Écarts liés** : SOC-01 ; SOC-02 ; SOC-03 ; SOC-04 ; SOC-05 ; IAM-08
- **Cotation** : vraisemblance 3, impact 3, niveau 9 (Élevé)
- **Justification** : Vraisemblance 3 : l'alerte SIEM a été tardive le 3 sept. 2026 et des logs AKS et Entra ID n'étaient pas exploités en août 2026 (§12, §13). Impact 3 : une détection tardive allonge la présence de l'attaquant ; aucune exfiltration massive n'a été identifiée lors de l'incident.
- **Traitement** : Réduire — actions T-06 ; T-07 ; T-08 ; T-09 ; T-31 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.8.15 ; A.8.16 ; A.5.24 ; A.5.25 ; A.5.26 ; A.5.22
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : couverture des logs et contrat MSSP révisé réduisent la probabilité d'une détection tardive (2) ; l'impact potentiel d'une intrusion reste majeur (3).

R-03 — Comptes actifs non justifiés (départs, externes, mobilités)

- **Scénario** : Un compte reste actif après un départ, une fin de mission ou un changement de fonction ; il est détourné ou abusé.
- **Propriétaire** : CISO
- **Écarts liés** : IAM-01 ; IAM-02 ; IAM-09
- **Cotation** : vraisemblance 3, impact 3, niveau 9 (Élevé)
- **Justification** : Vraisemblance 3 : deux cas documentés en 2026, un compte de consultant actif 11 jours (avril) et un rôle hérité d'un ancien projet (sept.) ; aucun abus observé dans le premier cas. Impact 3 : un compte non justifié donne un accès non autorisé à des systèmes internes.
- **Traitement** : Réduire — actions T-10 ; T-11 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.16 ; A.5.18 ; A.5.11
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : automatisation des départs et mobilités et revue des accès réduisent la probabilité (2) ; l'impact potentiel reste majeur (3).

R-04 — Exposition de secrets et d'identifiants techniques

- **Scénario** : Des secrets statiques ou présents dans d'anciens dépôts sont exploités pour accéder à des ressources.
- **Propriétaire** : CTO
- **Écarts liés** : IAM-07 ; DEV-04
- **Cotation** : vraisemblance 2, impact 4, niveau 8 (Élevé)
- **Justification** : Vraisemblance 2 : des secrets statiques subsistent et d'anciens dépôts ne sont pas assainis (§6, §7) ; aucune exploitation n'est constatée, mais des secrets ont dû être renouvelés après l'incident (§13). Impact 4 : les clés et secrets sont jugés critiques en confidentialité et intégrité (§5).
- **Traitement** : Réduire — actions T-12 ; T-13 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.17 ; A.8.4 ; A.8.24 ; A.8.28
- **Risque résiduel visé** : 1 × 3 = 3 (Faible). Résiduel : secrets dans Key Vault avec rotation et dépôts assainis rendent l'exploitation peu probable (1) ; des identités managées limitent l'étendue d'un secret compromis (impact 3).

R-05 — Mauvaise configuration cloud entraînant une exposition

- **Scénario** : Une ressource Azure créée manuellement ou mal configurée expose des données ou des services.
- **Propriétaire** : CIO
- **Écarts liés** : CLD-01 ; CLD-02
- **Cotation** : vraisemblance 3, impact 3, niveau 9 (Élevé)
- **Justification** : Vraisemblance 3 : un conteneur de stockage mal configuré a été détecté en février 2026 (§12) et des ressources restent créées manuellement (§4). Impact 3 : des dossiers KYC sont stockés dans le stockage objet (§4) ; l'exposition de février était limitée.
- **Traitement** : Réduire — actions T-14 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.8.9 ; A.8.3 ; A.5.23 ; A.8.32
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : Azure Policy et IaC réduisent les écarts de configuration (2) ; l'impact potentiel sur des données KYC reste majeur (3).

R-06 — Mise en production de code vulnérable

- **Scénario** : Des contrôles de sécurité non bloquants ou incomplets laissent passer une vulnérabilité exploitable ; changement urgent mal documenté.
- **Propriétaire** : CTO

- **Écarts liés** : DEV-01 ; DEV-02 ; DEV-03 ; CLD-04
- **Cotation** : vraisemblance 3, impact 3, niveau 9 (Élevé)
- **Justification** : Vraisemblance 3 : sur les applications historiques les résultats de scan créent un ticket sans bloquer le déploiement, le SAST couvre environ 80 % des dépôts (§7) ; hypothèse : des vulnérabilités atteignent donc régulièrement la production. Impact 3 : APIs et portail exposés à Internet.
- **Traitement** : Réduire — actions T-15 ; T-16 ; T-17 ; T-34 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.8.25 ; A.8.28 ; A.8.29 ; A.8.8 ; A.8.32
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : seuils de blocage homogènes et couverture complète réduisent la probabilité (2) ; l'exposition des APIs maintient un impact majeur (3).

R-07 — Indisponibilité prolongée de la plateforme de paiement

- **Scénario** : Une panne ou un sinistre dépasse les RTO car le PRA n'a pas été testé de bout en bout et le BIA n'est pas à jour.
- **Propriétaire** : CIO
- **Écarts liés** : CON-01 ; CON-02 ; CON-03 ; CON-04 ; CON-05
- **Cotation** : vraisemblance 2, impact 4, niveau 8 (Élevé)
- **Justification** : Vraisemblance 2 : aucune interruption majeure n'est rapportée, mais le test de juin 2026 a dépassé l'objectif (6 h 40 pour 4 h) et les tests de bascule sont irréguliers (§9). Impact 4 : une interruption empêche des centaines de commerçants d'encaisser et l'objectif de disponibilité est de 99,95 % (§1, §2).
- **Traitement** : Réduire — actions T-18 ; T-19 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.29 ; A.5.30 ; A.8.13 ; A.8.14
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : BIA validé et PRA éprouvé de bout en bout ramènent la durée d'une interruption dans les RTO (impact 3) ; la probabilité d'un sinistre reste inchangée (2).

R-08 — Défaillance d'un fournisseur critique ou de sa sécurité

- **Scénario** : Azure, le MSSP, l'eKYC ou l'OTP subit un incident ou ne respecte pas les exigences ; des clauses d'audit, de sortie ou de sous-traitance manquent.
- **Propriétaire** : CISO
- **Écarts liés** : FOU-01 ; FOU-02 ; FOU-03 ; FOU-04 ; SOC-04
- **Cotation** : vraisemblance 2, impact 4, niveau 8 (Élevé)
- **Justification** : Vraisemblance 2 : aucun incident fournisseur n'est rapporté, mais la grille d'évaluation n'est pas appliquée aux prestataires historiques et les contrats anciens sont hétérogènes (§10). Impact 4 : Azure et le MSSP sont jugés critiques pour la production, l'IAM technique et la détection (§10).
- **Traitement** : Réduire — actions T-20 ; T-21 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.19 ; A.5.20 ; A.5.21 ; A.5.22 ; A.5.23
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : évaluation, clauses contractuelles et plans de sortie limitent les conséquences d'une défaillance (impact 3) ; la probabilité dépend des tiers (2).

R-09 — Non-conformité réglementaire ou contractuelle

- **Scénario** : Des exigences (BCT, protection des données, PCI DSS, éventuellement RGPD) ne sont pas identifiées ou respectées ; sanction ou perte de contrat.
- **Propriétaire** : Risques & Conformité (DPO)
- **Écarts liés** : LEG-01 ; LEG-02 ; LEG-03
- **Cotation** : vraisemblance 3, impact 3, niveau 9 (Élevé)
- **Justification** : Vraisemblance 3 : l'applicabilité des textes et de PCI DSS reste à analyser et aucun registre des exigences n'est mentionné (§11) ; hypothèse : des exigences non identifiées existent probablement. Impact 3 : sanction, perte d'un contrat de grand compte (§1) ou obligations non respectées.
- **Traitement** : Réduire — actions T-22 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.31 ; A.5.34 ; A.5.36
- **Risque résiduel visé** : 1 × 3 = 3 (Faible). Résiduel : un registre des exigences tenu à jour rend une non-conformité non détectée rare (1) ; l'impact potentiel d'une sanction reste majeur (3).

R-10 — Divulgation de données sensibles hors des circuits prévus

- **Scénario** : Mauvaise classification, exports et documents partenaires non protégés, données de production dans des environnements non production.
- **Propriétaire** : CISO
- **Écarts liés** : ACT-01 ; ACT-02 ; CLD-03
- **Cotation** : vraisemblance 3, impact 3, niveau 9 (Élevé)
- **Justification** : Vraisemblance 3 : la classification n'est pas appliquée uniformément aux exports et documents partenaires, l'inventaire n'est pas consolidé et des jeux de données issus de la

production circulent en test (§5, §7, §12). Impact 3 : des données de transaction et KYC sont très sensibles en confidentialité (§5).
- **Traitement** : Réduire — actions T-23 ; T-24 ; T-25 ; T-35 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.9 ; A.5.12 ; A.5.13 ; A.5.14 ; A.8.11 ; A.8.31 ; A.8.33
- **Risque résiduel visé** : 2 × 3 = 6 (Modéré). Résiduel : marquage, règles de partage et masquage contrôlé réduisent la probabilité (2) ; la sensibilité des données maintient l'impact (3).

R-11 — Gouvernance du SMSI insuffisante

- **Scénario** : Des rôles flous, des décisions non suivies et l'absence de pilotage (risques, audits, indicateurs) empêchent de démontrer la maîtrise des risques.
- **Propriétaire** : CEO
- **Écarts liés** : GOV-01 ; GOV-02 ; GOV-03 ; GOV-04 ; GOV-05 ; GOV-06 ; PIL-01 ; PIL-02
- **Cotation** : vraisemblance 4, impact 3, niveau 12 (Critique)
- **Justification** : Vraisemblance 4 : la situation existe en continu (rôles non formalisés, suivi des décisions dispersé, §3 et §12). Impact 3 : la direction ne peut pas démontrer la maîtrise des risques (§13), ce qui menace la certification visée et les contrats de grands comptes.
- **Traitement** : Réduire — actions T-26 ; T-27 ; T-28 ; T-29 ; T-30 ; T-32 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.5.1 ; A.5.2 ; A.5.4 ; A.5.35 ; A.5.36
- **Risque résiduel visé** : 2 × 2 = 4 (Modéré). Résiduel : rôles approuvés, suivi centralisé et revue de direction réduisent la probabilité (2) ; l'impact devient modéré car les écarts seront détectés et traités (2).

R-12 — Accès physique non autorisé ou perte d'équipement au siège

- **Scénario** : Un accès non autorisé aux locaux, ou la perte ou le vol d'un poste d'administration ou d'un équipement réseau, expose des accès ou des données.
- **Propriétaire** : CIO
- **Écarts liés** : (aucun écart relevé dans le cas)
- **Cotation** : vraisemblance 2, impact 2, niveau 4 (Modéré)
- **Justification** : Vraisemblance 2 : le siège ne contient que des équipements réseau, des services locaux limités et des postes d'administration (§4) ; aucun incident physique n'est rapporté. Impact 2 : la production est dans Azure ; un poste perdu serait protégé par l'EDR et le MFA mais reste un vecteur d'accès (hypothèse).
- **Traitement** : Réduire — actions T-36 (voir `registres/Registres_SMSI.xlsx`, onglet Traitement) ; contrôles de l'Annexe A visés : A.7.1 ; A.7.2 ; A.7.3 ; A.7.4 ; A.7.8 ; A.7.9 ; A.7.13
- **Risque résiduel visé** : 1 × 2 = 2 (Faible). Résiduel : contrôle d'accès aux locaux, chiffrement des postes et procédure de perte ou de vol réduisent la probabilité (1) ; l'impact reste modéré (2).

5. Risques résiduels et acceptation

Les cotes résiduelles sont des **cibles** : elles supposent que les actions du plan soient réalisées dans les délais prévus.

- **Acceptables** (niveau ≤ 3) : R-04, R-09, R-12.
- **Modérés, au-dessus du seuil** : R-01, R-02, R-03, R-05, R-06, R-07, R-08, R-10, R-11. La clause 6.1.3 exige que les propriétaires de risques approuvent le plan de traitement et acceptent les risques résiduels. Pour ces risques, le sponsor (CEO) devra soit accepter formellement le niveau résiduel, soit demander des actions complémentaires.

6. Limites et hypothèses

- La cotation repose uniquement sur l'énoncé du cas ; aucune preuve détaillée n'a été examinée.
- Plusieurs vraisemblances sont des hypothèses (R-06, R-09, R-12) et sont signalées comme telles dans leur justification.
- Les échelles, les seuils et les cibles résiduelles sont des propositions de travail.
- Un risque peut se recouper avec un autre (par exemple R-01 et R-03 sur les identités) : le regroupement est un choix d'analyse.

7. Prochaines étapes

1. Valider les cotations avec les propriétaires de risques lors des ateliers.

2. Faire approuver le plan de traitement et accepter les risques résiduels.
3. Relire la déclaration d'applicabilité établie à partir de ces risques (09-declaration-applicabilite.md).
4. Réévaluer les risques à intervalles planifiés et après tout changement significatif (clause 8.2).